

Manual 34 — Implementação controlada de Gestão de Informações de Privacidade ISO/IEC 27701:2025

****Idioma:**** Português do Brasil (pt-BR) — tradução não oficial do projeto.

****Baseline:**** ISO/IEC 27701:2025, Edição 2. O texto normativo protegido da ISO não é reproduzido.

****Limite:**** esta orientação de implementação não estabelece, por si só, certificação ou conformidade legal.

Chapter 01 — Propósito, escopo e hierarquia controlada de fontes

Defina o objetivo do PIMS, limites organizacionais, classes de informação, produtos, serviços, entidades jurídicas, jurisdições e interfaces. Mantenha separados os conceitos da ISO/IEC 27701:2025, a integração com ISO/IEC 27001/27002, leis vinculantes, orientações regulatórias, contratos e procedimentos internos.

****Controles de implementação:**** aprovar escopo, exclusões, interfaces e responsáveis por fontes; datar cada reverificação.

****Evidência:**** escopo aprovado, registro de fontes, aplicabilidade e log de verificação.

Chapter 02 — Contexto do PIMS e limites organizacionais

Documente condições internas e externas que afetam a gestão de privacidade, incluindo modelo de negócio, escala de tratamento, sensibilidade, tecnologia, outsourcing, geografia e expectativas de stakeholders. Converta o contexto em premissas explícitas de projeto e gatilhos de revisão.

****Controles:**** revisão pelo menos anual e após mudanças materiais; vincular mudanças a risco e escopo.

****Evidência:**** avaliação de contexto, diagrama de limites, log de mudanças e aprovação.

Chapter 03 — Partes interessadas e inventário de requisitos de privacidade

Identifique titulares, clientes, reguladores, colaboradores, fornecedores, parceiros, auditores e outras partes relevantes. Traduza requisitos aplicáveis em obrigações controladas sem tratar toda expectativa como lei.

****Controles:**** manter responsável, fonte, aplicabilidade, status e evidência.

****Evidência:**** registro de partes interessadas, inventário de requisitos e matriz de rastreabilidade.

Chapter 04 — Determinação do escopo do PIMS e registro de aplicabilidade

Defina atividades de tratamento, sistemas, locais, entidades, serviços e terceiros cobertos pelo PIMS. Registre justificativas para exclusões e dependências para que declarações de readiness não excedam o escopo efetivamente gerenciado.

****Controles:**** aprovação da gestão, mapeamento de dependências e reconciliação com inventários.

****Evidência:**** escopo PIMS, registro de aplicabilidade e referências de inventário.

Chapter 05 — Liderança, política e accountability

A alta gestão deve estabelecer direção, aprovar política, atribuir accountability, fornecer recursos e revisar desempenho. Integre privacidade com enterprise risk e information security governance.

****Controles:**** política aprovada, executivo accountable, cadência de governança e rota de escalonamento.

****Evidência:**** política, charter, atas, decisões e aprovações de recursos.

Chapter 06 — Papéis de governança de privacidade e segregação de funções

Defina responsabilidades para risco, ownership do tratamento, sistemas, interpretação legal, segurança, procurement, resposta a incidentes, auditoria interna e management review. Separe operação e revisão independente quando viável.

****Controles:**** RACI, autoridades delegadas, revisão de conflitos e responsabilidades de backup.

****Evidência:**** matriz de papéis, descrições e registros de delegação.

Chapter 07 — Gestão de riscos e oportunidades de privacidade

Use método repetível para identificar riscos provenientes de tratamento, tecnologia, pessoas, fornecedores, jurisdições e mudanças de ciclo de vida. Avalie probabilidade e consequência usando critérios definidos e documente decisões de tratamento.

****Controles:**** metodologia aprovada, ownership, autoridade de aceitação e reavaliação periódica.

****Evidência:**** registro de riscos, planos, aceitações e histórico de revisão.

Chapter 08 — Objetivos, métricas e planejamento de privacidade

Defina objetivos mensuráveis ligados a risco, prioridades de negócio, obrigações e melhoria contínua. Especifique indicador, meta, responsável, frequência e limiar de remediação.

****Controles:**** objetivos aprovados e regras de qualidade de dados.

****Evidência:**** registro de objetivos, KPI/KRI, dashboards e ações.

Chapter 09 — Recursos, competência, awareness e comunicações

Identifique competências necessárias para governance, engineering, operations, procurement, incident response, audit e liderança. Forneça treinamento por papel e defina comunicações internas/externas.

****Controles:**** critérios de competência, planos de treinamento, acompanhamento e rotas aprovadas.

****Evidência:**** matriz de competência, registros de treinamento e plano de comunicação.

Chapter 10 — Governança de informação documentada

Controle políticas, procedimentos, registros, workpapers, templates e evidências do PIMS para garantir versão, aprovação, proteção, retenção, recuperação e mudanças autorizadas.

****Controles:**** ownership, versionamento, aprovação, retenção, acesso e descarte.

****Evidência:**** registro documental, histórico, cronograma de retenção e acessos.

Chapter 11 — Planejamento e controle operacional

Transforme requisitos e tratamentos de risco em procedimentos repetíveis para intake, uso, sharing, storage, change, retention, deletion, interação com fornecedores e exceções.

****Controles:**** procedimentos, responsáveis, aprovação de exceções e revisão de impacto de mudanças.

****Evidência:**** procedimentos, logs, registro de exceções e revisões.

Chapter 12 — Responsabilidades do PII controller

Quando a organização atuar como controller, governe finalidades, instruções de tratamento, transparência, suporte a direitos, sharing, retention, decisões de risco e oversight de processors. Mantenha obrigações legais por jurisdição como camada separada.

****Controles:**** determinação de papel, registros de finalidade, oversight e escalonamento legal.

****Evidência:**** avaliação de controller, processing records, notices e registros de oversight.

Chapter 13 — Responsabilidades do PII processor

Quando a organização atuar como processor, controle recebimento, validação, implementação e alteração de instruções do controller. Gerencie subprocessors, confidencialidade, segurança, devolução/exclusão, incident support e obrigações contratuais.

****Controles:**** registro de instruções, contratos, subprocessor governance e encerramento.

****Evidência:**** avaliação de processor, logs, contratos e prova de devolução/exclusão.

Chapter 14 — Processos de suporte a direitos dos titulares

Implemente intake, verificação de identidade, routing, fulfillment, exceções, aprovação e evidência para direitos aplicáveis. Não presuma um conjunto universal de direitos ou prazos.

****Controles:**** workflow por jurisdição, salvaguardas de identidade, tracking e revisão legal.

****Evidência:**** registro de solicitações, verificação, resposta e decisões de exceção.

Chapter 15 — Suporte a finalidade legítima e registros de tratamento

Mantenha registros que identifiquem finalidade, owner, categorias de dados, titulares, sistemas, destinatários, jurisdições, retenção e base legal/contratual quando aplicável. Determinações de base legal pertencem a funções autorizadas.

****Controles:**** inventário de tratamento, revisão de mudança de finalidade e owner certification.

****Evidência:**** processing records, aprovações, mapeamentos legais e histórico.

Chapter 16 — Privacy by design e privacy by default

Integre privacidade a produto, serviço, arquitetura, procurement, analytics e change management antes do deployment. Configurações padrão devem refletir objetivos e decisões de risco aprovadas.

****Controles:**** design gates, requisitos, architecture review e aprovação de desvios.

****Evidência:**** assessments, requisitos, decisões e exceções.

Chapter 17 — Minimização, exatidão, retenção e descarte

Limite coleta e uso à finalidade aprovada e necessidade operacional, mantenha exatidão adequada e implemente regras de retenção e exclusão, anonimização, devolução ou arquivamento verificáveis.

****Controles:**** justificativa de dados, retention schedule, deletion workflow e legal hold.

****Evidência:**** revisões de minimização, quality checks, regras e disposal logs.

Chapter 18 — Transparência e suporte a notices

Mantenha descrições claras e controladas do tratamento e revise notices quando houver mudanças materiais em processamento, destinatários, tecnologia, geografia ou requisitos.

****Controles:**** ownership, triggers, versionamento e revisão de acessibilidade.

****Evidência:**** inventário de notices, aprovações, histórico e assessments.

Chapter 19 — Consentimento e gestão de preferências

Quando consentimento ou preferências fizerem parte do modelo aplicável, registre decisão, contexto, versão, data/hora, escopo e retirada/alteração de forma auditável. Não use consentimento como substituto automático de análise jurídica.

****Controles:**** critérios, preference store, retirada e propagação downstream.

****Evidência:**** registros de consentimento, preferências, retiradas e testes de sincronização.

Chapter 20 — Governança de fornecedores, subprocessors e terceiros

Aplique privacy due diligence baseado em risco antes do onboarding e durante o ciclo de vida. Defina papéis, fluxos, jurisdições, contratos, expectativas, incident duties, audit rights, mudanças e exit.

****Controles:**** tiering, due diligence, contract review, monitoring e exit controls.

****Evidência:**** assessments, contratos, monitoring, remediation e encerramento.

Chapter 21 — Transferências internacionais e mapeamento jurisdicional

Mapeie onde PII é coletada, acessada, armazenada, suportada e transferida. Encaminhe decisões sobre mecanismos e adequação a funções jurídicas/privacy qualificadas porque variam por jurisdição.

****Controles:**** inventário de localização, transfer review, mecanismo aprovado e change control.

****Evidência:**** transfer map, determinação legal, contratos e reavaliações.

Chapter 22 — Integração de controles de segurança com ISO/IEC 27001 e 27002

Coordene controles de privacidade com o sistema de gestão de segurança e salvaguardas técnicas. Riscos de privacidade podem exigir controles adicionais; controles de segurança isoladamente não demonstram privacy compliance.

****Controles:**** mapping privacy-security, ownership compartilhado, gaps e exceções.

****Evidência:**** crosswalk, vínculos risk/control, testes e remediation.

Chapter 23 — Suporte a incidentes de privacidade e breach response

Integre avaliação de privacidade à resposta a incidentes para determinar dados, pessoas, jurisdições, obrigações contratuais, possíveis notificações, containment, remediation e preservação de evidências. Decisões de notificação são jurisdicionais.

****Controles:**** privacy triage, rota legal/regulatória, evidence preservation e lessons learned.

****Evidência:**** incident record, impact assessment, notification decision e remediation.

Chapter 24 — Arquitetura de registros, evidências e rastreabilidade

Defina objetos de evidência para provar decisões, operação de controles, reviews, exceções e corrective actions. Vincule evidência a requisito, risco, controle, owner, sistema/processo, período e aprovação.

****Controles:**** taxonomia, naming/retention, acesso e integrity checks.

****Evidência:**** evidence index, traceability matrix, retention e integrity metadata.

Chapter 25 — Monitoring, measurement, analysis e evaluation

Meça desempenho do PIMS e avalie se os controles operam conforme esperado. Diferencie métricas operacionais de conclusões de assurance.

****Controles:**** data owners, regras de cálculo, thresholds, cadence e triggers de corrective action.

****Evidência:**** dashboards, source records, trend analysis e ações.

Chapter 26 — Internal audit do PIMS

Planeje auditorias baseadas em risco com independência suficiente. Defina escopo, critérios, evidência, sampling, findings, reporting, remediation e follow-up.

****Controles:**** audit program, competência/independência, classificação de findings e closure validation.

****Evidência:**** plano, workpapers, findings, respostas e encerramento.

Chapter 27 — Management review

A gestão deve avaliar suitability, adequacy, effectiveness, riscos significativos, auditorias, incidentes, objetivos, recursos, mudanças de stakeholders e prioridades de melhoria.

****Controles:**** agenda definida, inputs, tracking de decisões e accountability.

****Evidência:**** review pack, minutes, decisões, ações e encerramento.

Chapter 28 — Nonconformity e corrective action

Quando requisito ou controle falhar, contenha, avalie impacto, identifique causa, revise implicações sistêmicas, corrija e verifique eficácia antes de encerrar.

****Controles:**** intake, root-cause method, ownership, prazos e effectiveness review.

****Evidência:**** nonconformity record, root cause, remediation e validation result.

Chapter 29 — Melhoria contínua

Use tendências de risco, auditorias, incidentes, métricas, feedback, mudanças regulatórias/tecnológicas e lessons learned para priorizar melhorias.

****Controles:**** backlog, critérios de prioridade, benefit/risk assessment e governance review.

****Evidência:**** backlog, roadmap, implementation records e outcome measures.

Chapter 30 — Limite de mapeamento regulatório e contratual

Mapeie controles/evidências do PIMS para leis, regulamentos, orientações, requisitos de clientes e contratos sem afirmar equivalência. Um crosswalk é auxílio de rastreabilidade, não prova de conformidade automática.

****Controles:**** fonte/data/versão, rationale, legal review quando aplicável e non-equivalence statement.

****Evidência:**** crosswalk register, rationale, approvals e histórico.

Chapter 31 — Certification readiness, assurance e evidence package

Prepare evidência controlada para readiness interno e assurance externo, preservando o limite com certificação acreditada. Declarações de certificação só podem se basear em evidência externa válida.

****Controles:**** evidence index, readiness review, gap closure e claim approval.

****Evidência:**** readiness report, evidence pack, gap register e certificados válidos quando existirem.

Chapter 32 — Reverificação de fontes e roadmap de implementação

Antes de cada release, confirme edição/status atual da ISO/IEC 27701, amendments/corrigenda relevantes, dependências e overlays materiais. Congele identidades de fonte antes da geração do candidato e reinicie o ciclo após mudança material.

****Controles:**** source verification, release checklist, source freeze, change triggers e predecessor check.

****Evidência:**** source-state record, checklist, provenance manifest, QA results e publication approval.

Declaração controlada de release

Este manual é orientação original de implementação. Não é publicação da ISO, não é tradução autorizada pela ISO e não confere, por si só, certificação ou conformidade legal. Conclusões jurídicas devem ser feitas por profissionais autorizados conforme os fatos e a legislação vigente.